THE ART OF NOT BEING SEEN: EVADING ENDPOINT SECURITY

By: Ray Goh

$whoami



Yo, I'm **Ray** :D

exp

- Incident Response Consultant @ Mandiant (part of Google Cloud)
- Prev @ Cloudflare (Threat Detection & Incident Response Intern)
- CS @ UNSW Sydney

non-work exp

- I love gacha + rhythm games!! (Genshin/HSR/Maimai/Osu!/PJSK)
- otaku and massive caffeine addict

Disclaimer: This talk represents my own opinions/research and is not affiliated with my employer in any capacity.

How do game cheats get detected?

Eg. Wallhack



reads memory

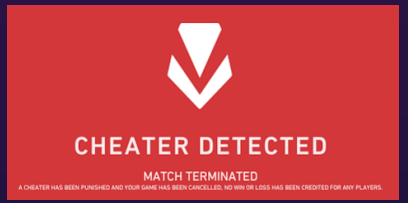
Injects code

Game process
Enemy positions stored in memory

Anticheat
Checks selected endpoint evidence

detects

unauth memory access
process code injection



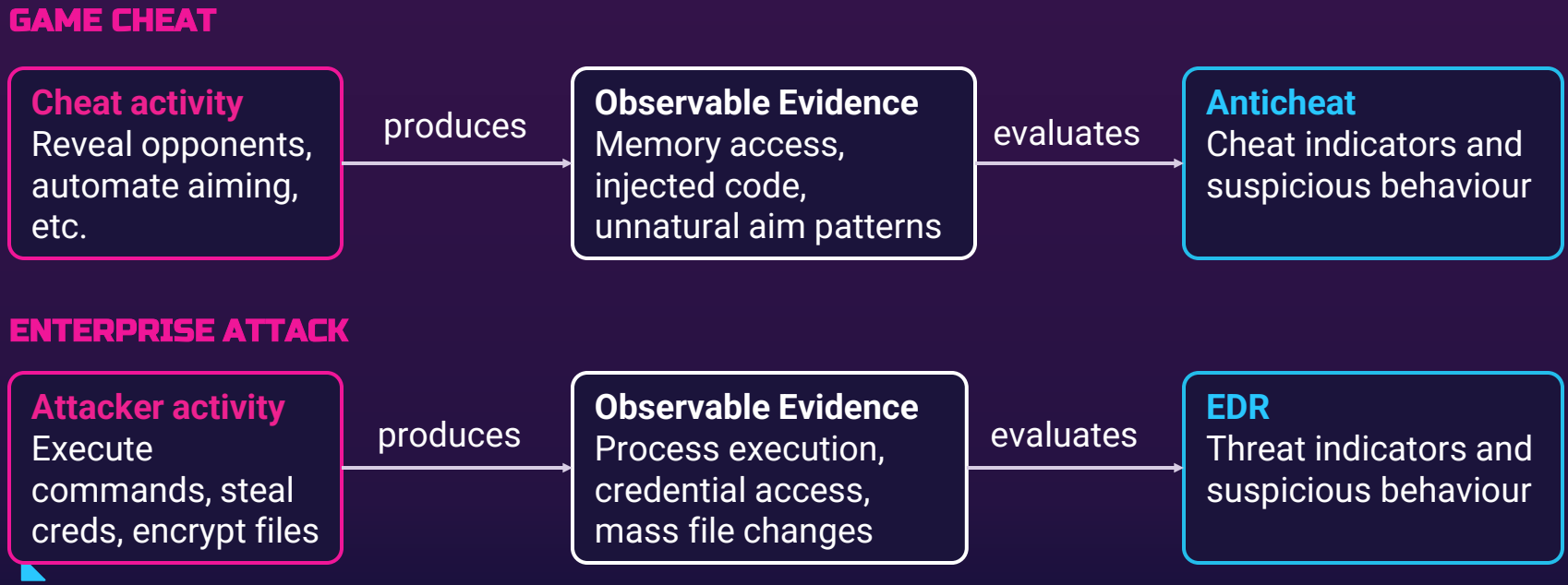
Examples of anticheat software

BATTLEYE
THE ANTI-CHEAT GOLD STANDARD

easy™
ANTI-CHEAT

Game Cheats and EDR Evasion

Different targets, but similar detection mechanisms



Today's Talk Aims to Answer:

What can an EDR observe on a Windows host?

How do attackers interfere with endpoint visibility or detection?

How do incident responders investigate when endpoint visibility fails?

01 WHAT DOES AN EDR DO?

How We Got Here: AV → EDR



***Creeper**: The first computer worm [1971]*

Antivirus (1980s-)
Signature-based: Hashes, byte sequences
Blocks file at the moment of the scan
Can be easily evaded by files it's never seen (eg. Polymorphic malware) or lack thereof (fileless malware)

EDRs (2013-)
Behaviour-based: Process, file, network, registry activity
Continuously logs information
Can search backwards after an alert

What is an EDR?

EDR stands for **Endpoint Detection and Response**

Observes endpoint activity to identify threats

Retains historical activity for investigation

Supports response actions

Examples of EDR Solutions



Crowdstrike Falcon



MDE



Elastic Defend

Key capabilities of an EDR



Collect

Endpoint Telemetry
Process creation, file/registry writes, network connections, etc.



Analyse

Identify suspicious activity
Evaluate events + behaviour with rules/indicators/models



Alert

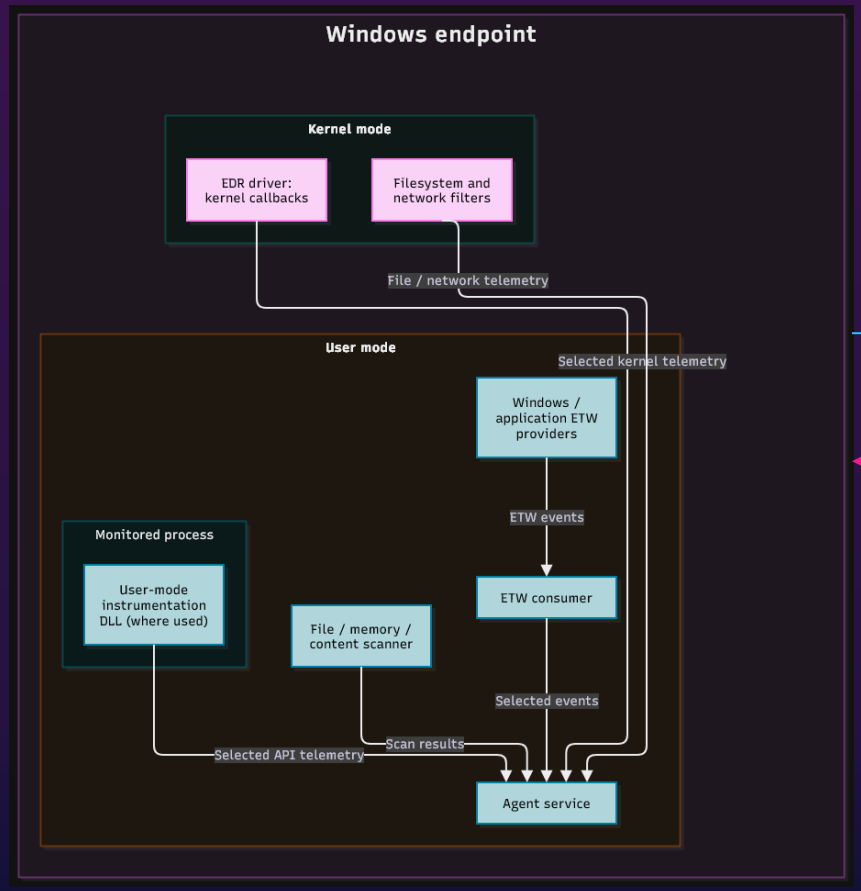
Surface detections for investigation



Respond

Act remotely + at scale
Eg. Process termination, file quarantine, host isolation

Simple EDR Agent Architecture

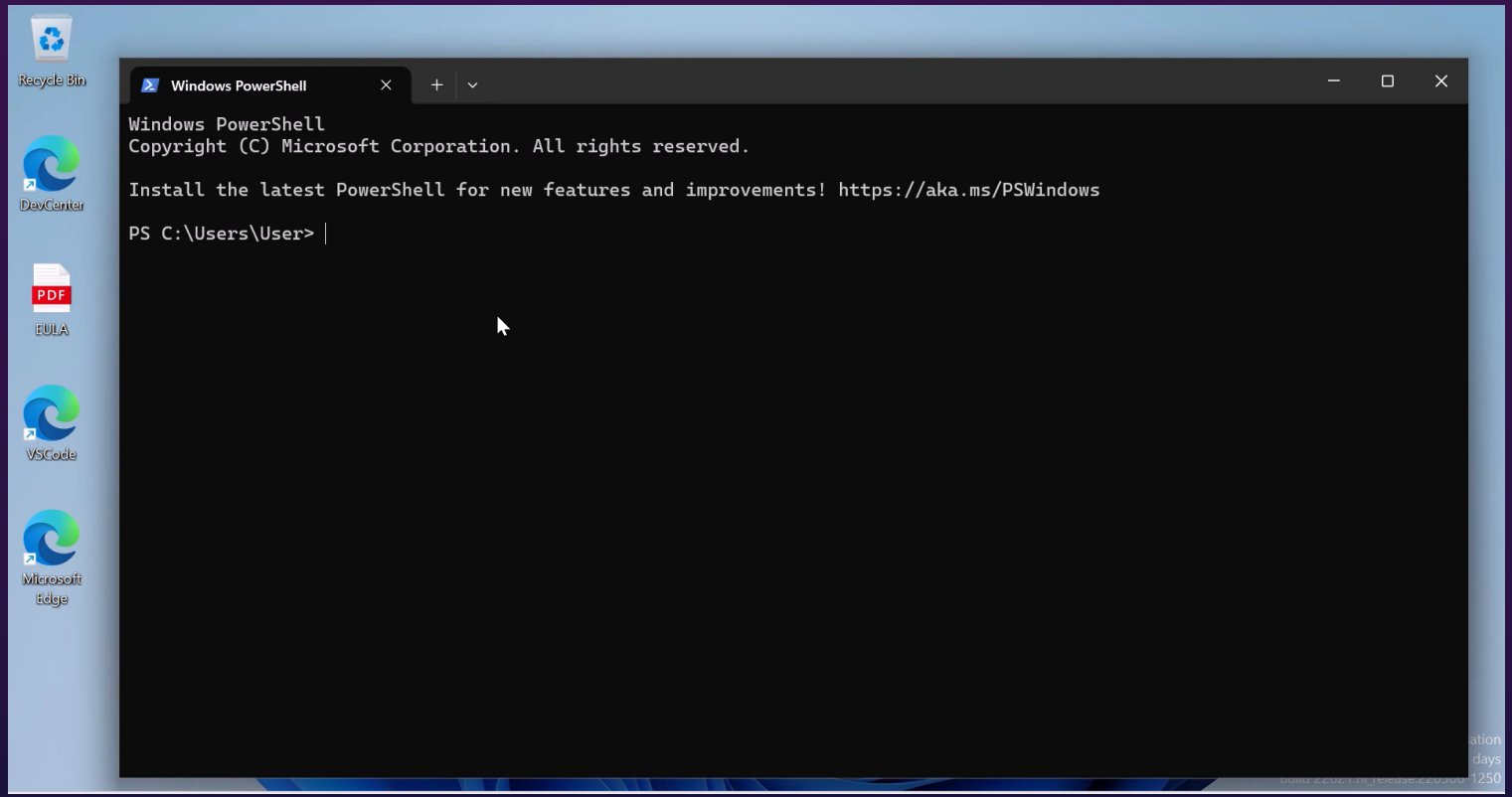


Telemetry + alerts

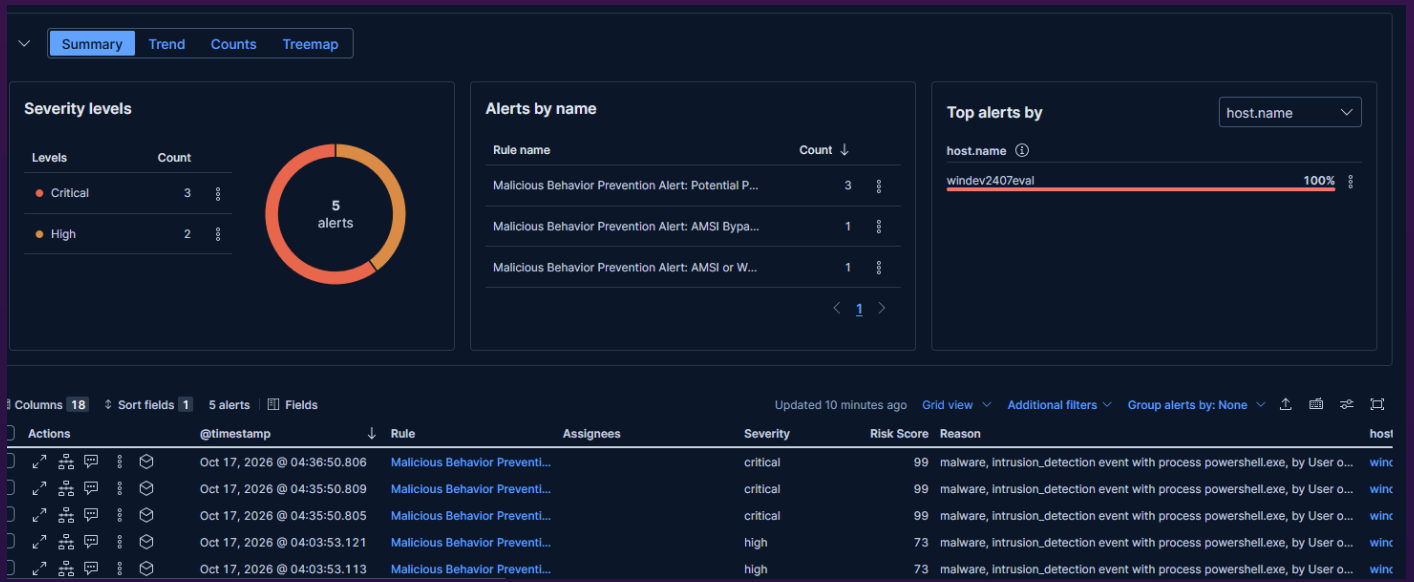
Backend
Analytics, storage and management

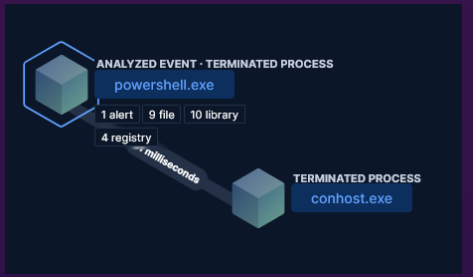
Policy/Response commands

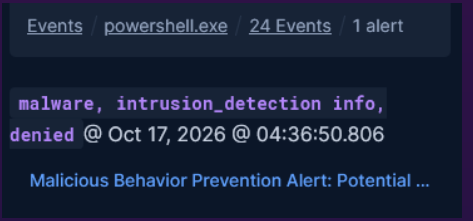
Demo: Elastic Defend in Action



Demo: Elastic Defend in Action







Rule: Potential Invoke-Mimikatz PowerShell Script

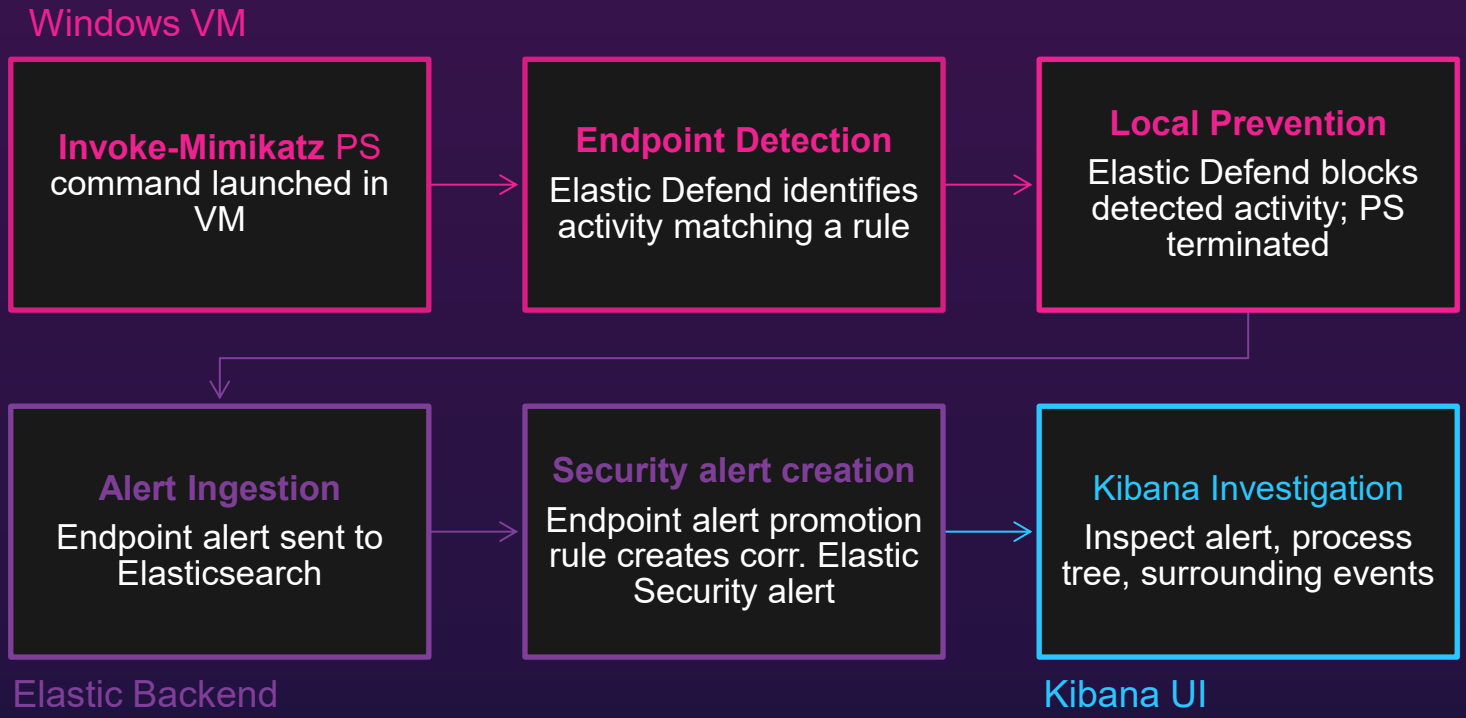
Description

Identifies PowerShell script block content containing Invoke-Mimikatz or Mimikatz commands used to dump credentials, extract password stores, export certificates, or use alternate authentication material. These patterns can indicate in-memory credential access and require reconstructed script context and follow-on telemetry to assess impact.

Custom highlighted fields

@timestamp
user.name
user.id
user.domain
powershell.file.script_block_text
powershell.file.script_block_id
powershell.sequence
powershell.total
file.path
file.directory
file.name
process.pid
host.name
host.id
powershell.file.script_block_length

Elastic Demo: Tracing from Event to Alert



02

THE VALUE OF EVASION

What can an attacker gain from successful evasion?



Payload execution: Run code that would otherwise be blocked



Greater Dwell Time: More time to establish persistence, move laterally, etc.



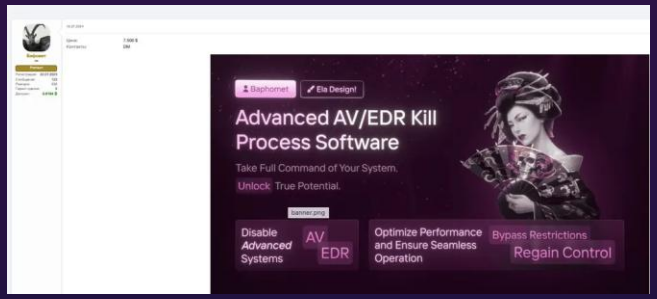
Less Interference With Objective: Ransomware deployment, data exfil

The Commoditization of Evasion?

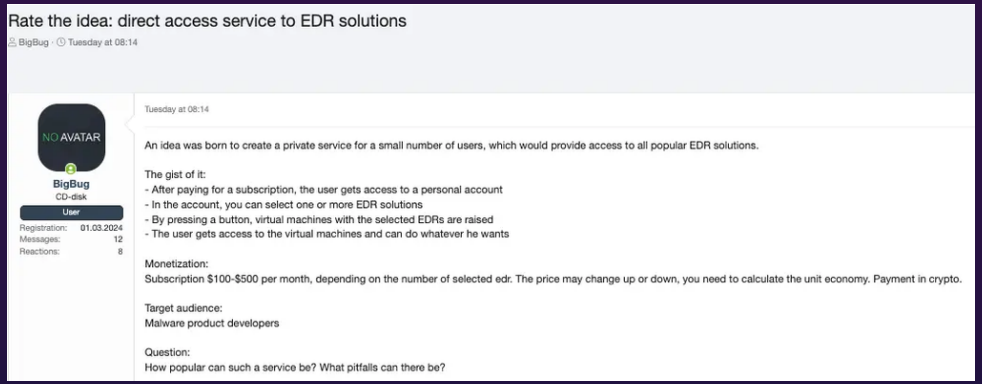
Development of EDR evasion techniques is costly, so there's a (black) market for it

- EaaS: $350/month, $300/bypass
- EDR evasion within an encryption locker as much as $7500 - $10000





Baphomet AV/EDR Kill Process Software listing



EDR Evasion subscription services

Source: XSS form, ExtraHop (2024)

What Evasion Targets

Goal	Target	Effect (if successful)
Kill/Blind	Agent service, kernel callbacks, or sources feeding ETW events/scan results	Interrupt reporting or response, suppress selected events/content inspection
Avoid	Inspection performed via hooking DLL inside monitored processes	Selected calls reach kernel w/o passing through the user-mode hook. Kernel telemetry may remain available
Blend In	Detection logic	Activity is collected, but malicious intent may be harder to establish.

Evasion Tradeoffs

Kill/Blind

- **Pros**: Impaired monitoring/response for subsequent malicious activity
- **Cons**: Agent silence is a loud signal. Greater privileges needed + risk of crashes

Avoid

- **Pros**: Bypass a specific inspection point without stopping the agent
- **Cons**: Other sensors can still detect events, bypass may create its own suspicious traces

Blend In

- **Pros**: Lower detection likelihood since malicious actions look like routine activity
- **Cons**: Less room for attackers to act without standing out, and all activity is logged

03

EDR EVASION MECHANISMS

Common EDR Evasion Mechanisms

How attackers hide malicious activity, bypass inspection, or disable EDR components

AMSI bypass	Event Tracing for Windows (ETW) Patching	User-mode hook evasion (DLL unhooking, direct/indirect syscalls)	Living Off The Land (LOTL)
Process Injection	Obfuscation, Packing, Sleep Masking	Infrequent Beaconing	Bring Your Own Vulnerable Driver (BYOVD)

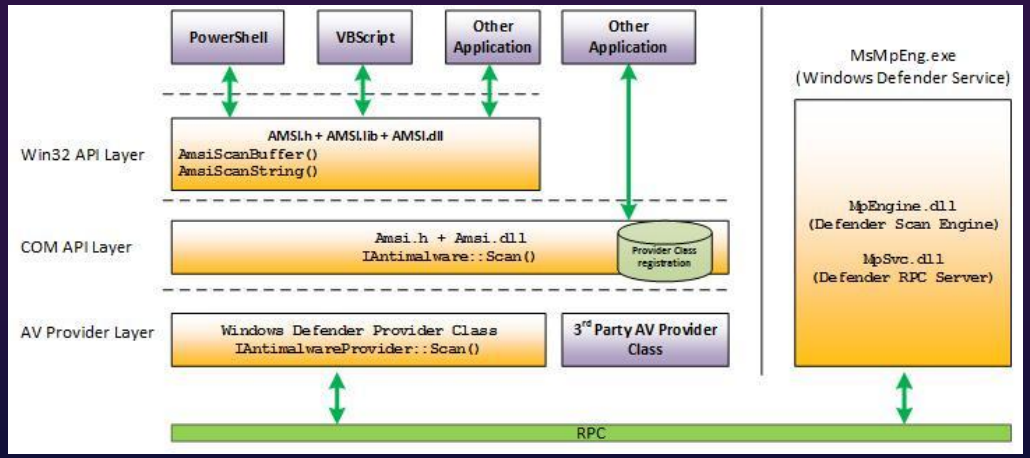
*Techniques can be combined, as bypassing one inspection path doesn't necessarily bypass the EDR.

AMSI Bypass with AmsiScanBuffer

Windows Antimalware Scan Interface (AMSI) lets apps like PS, VBScript submit content for scanning

```
PS C:\Users\hysan> $testString = "AMSI Test Sample: " + "7e72c3ce-861b-4339-8740-0ac1484c1386"
PS C:\Users\hysan> Invoke-Expression $testString
Invoke-Expression : At line:1 char:1
+ AMSI Test Sample: 7e72c3ce-861b-4339-8740-0ac1484c1386
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
This script contains malicious content and has been blocked by your antivirus software.
At line:1 char:1
+ Invoke-Expression $testString
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ParserError: (:) [Invoke-Expression], ParseException
    + FullyQualifiedErrorId : ScriptContainedMaliciousContent,Microsoft.PowerShell.Commands.InvokeExpressionCommand
```

Normally, the script host calls AmsiScanBuffer to submit content for inspection



AMSI Bypass with AmsiScanBuffer

Goal: Modify AmsiScanBuffer inside user-mode memory to disrupt content inspection

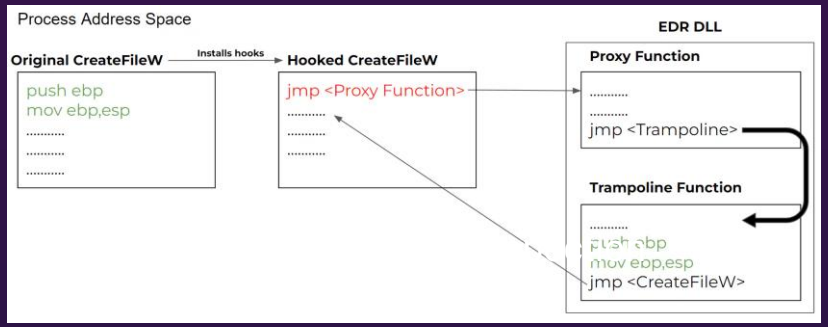
Locate function : Attacker-controlled code identifies AmsiScanBuffer in loaded amsi.dll

Make memory writable: Code pages are normally protected against writes, but WinAPIs like VirtualProtect can change protection of memory region

Alter function behaviour: Attacker modifies AmiScanBuffer's instructions so the normal scanning path is skipped or result handling is disrupted

Skipping the EDR's user-mode hook with direct syscalls

Inline Hooking



EDR patches fn entry to redirect calls into its DLL for inspection + to allow/block the operation

Direct Syscalls

```
; Procedure for the NtAllocateVirtualMemory syscall
NtAllocateVirtualMemory PROC
    mov r10, rcx                    ; Move the contents of rcx to r10. This is necess
    mov eax, wNtAllocateVirtualMemory ; Move the syscall number into the eax register.
    syscall                         ; Execute syscall.
    ret                             ; Return from the procedure.
NtAllocateVirtualMemory ENDP        ; End of the procedure.
```

Program supplies syscall no. + arguments → executes own syscall w/o entering hooked function

Hooked API Path	Direct Syscall
Program → ntdll entry → **EDR inspection** → syscall → kernel	Program's own syscall stub → kernel

While direct syscalls skip the user-mode hook, kernel monitoring can still view the operation + identify the syscall's origin

Source: Palo Alto Networks, "A Deep Dive Into Malicious Direct Syscall Detection," Feb 2024.

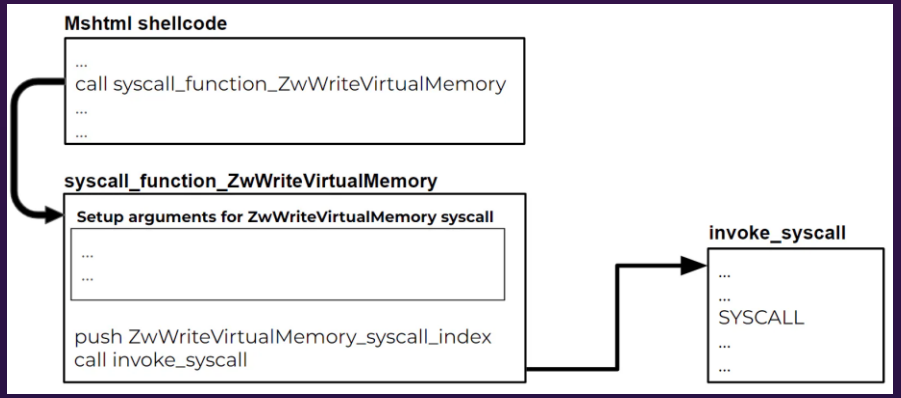
In The Wild: Lumma Stealer loader using direct syscalls

Resolve syscall numbers

```
70C71836 lea     ecx, [ebp+var_808_ntdll_path]
70C7183C call    Read_file
70C71841 add     esp, 8
70C71844 mov     eax, [ebp+var_280ZwCreateSection_Hash]
70C7184A push    eax
70C7184B mov     ecx, [ebp+var_28_ntdll_buffer]
70C7184E push    ecx
70C7184F call    get_syscall_num ; ZwCreateSection
70C71854 add     esp, 8
70C71857 mov     [ebp+var_35C_ZwCreateSection_OpCode], eax
70C7185D mov     edx, [ebp+var_284_ZwMapView_Hash]
70C71863 push    edx
70C71864 mov     eax, [ebp+var_28_ntdll_buffer]
70C71867 push    eax
70C71868 call    get_syscall_num ; ZwMapViewOfSection
70C7186D add     esp, 8
70C71870 mov     [ebp+var_358_ZwMapView_OpCode], eax
```

Reads ntdll.dll from disk + extracts syscall no. for ops (eg. Section creation, mapping)

Invoke syscall from loader-controlled code



Code in overwritten mshtml.dll memory preps arguments + passes selected no. to a shared syscall invoker

Heaven's Gate: invoker switches from 32-bit to 64-bit execution for the syscall, then switches back
Purpose: inject another payload into cmd.exe using direct syscalls for memory and thread operations.

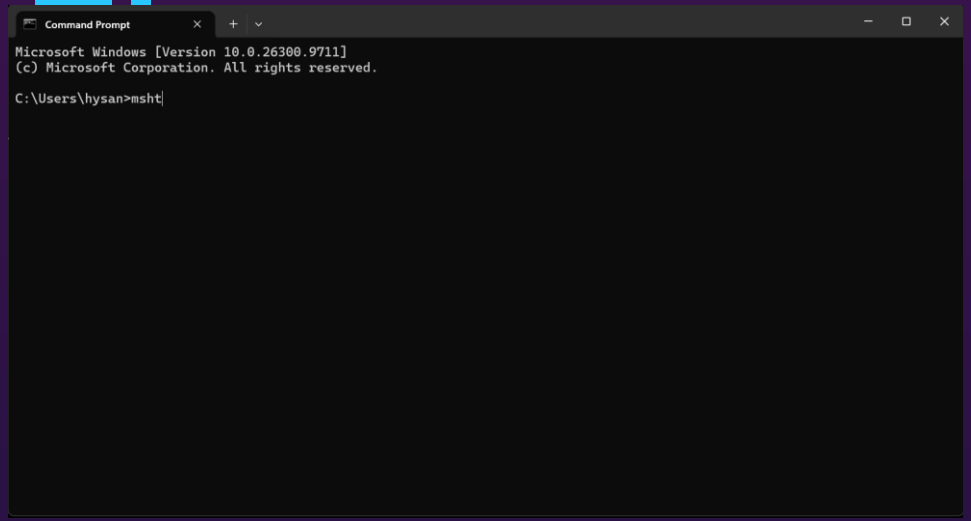
Source: Palo Alto Networks, "A Deep Dive Into Malicious Direct Syscall Detection," Feb 2024.

Living off The Land w. LOLBINS

Common Tools	Purpose	Attacker Objective
powershell.exe	Automate administration + system mgmt	Payload delivery + execution, perform attacker tasks
rundll32.exe	Invoke functions in DLLs	Malicious DLL code execution
mshta.exe	Run HTML Apps + embedded scripts	Script execution

While LOTL can reduce distinctive malware artifacts, evasion still depends on whether the tool's use escapes behavioural detection.

LOTL Demo



Initial Access through MSHTA + ClickFix (2025)

```
IXMLDOMNode._00000029("base64");
IXMLDOMElement.dataType("bin.base64");
IXMLDOMElement.text("<base64 payload>";
IXMLDOMElement.nodeTypedValue();
_Recordset.Fields();
Fields.Append("mBinary", "201", "6668");
_Recordset.Open();
_Recordset.AddNew();
_Recordset.Fields("mBinary");
_Recordset.Update();
_Recordset.Fields("mBinary");
Field.Value();
IShellWindows.Item();
IWebBrowser2.Document();
IShellFolderViewDual3.Application();
IShellDispatch6.ShellExecute("POWerSHEll", "& (gi C:\W*\S*4\W*\v*\p*ell.exe) -En JA", "", "open", "0");
```

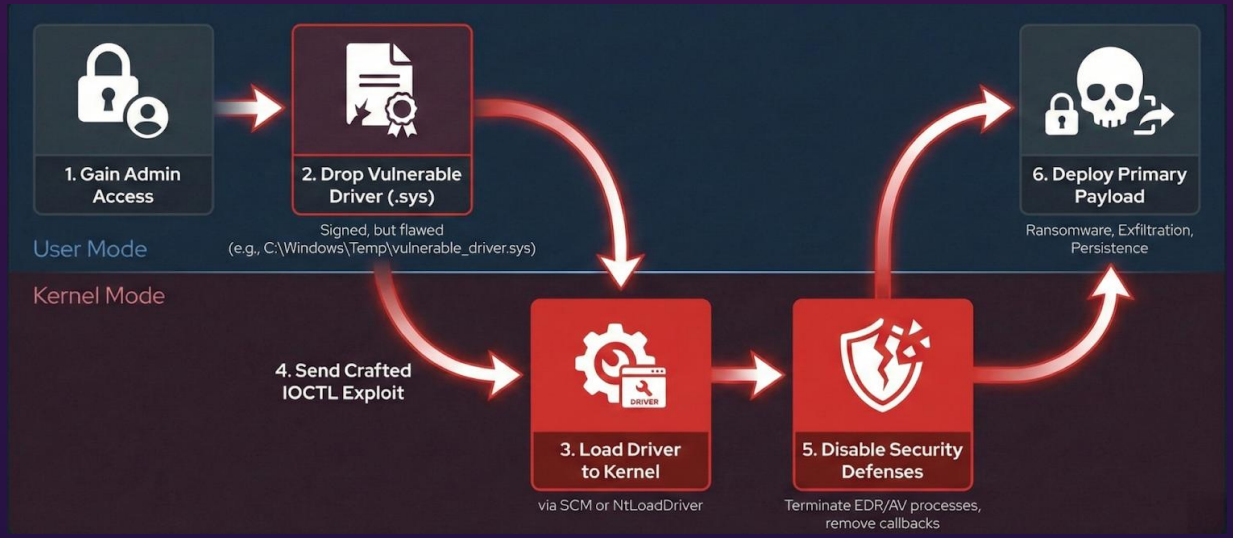
A ClickFix prompt tricks the victim into running mshta.exe, which fetches a remote HTA whose VBScript decodes and launches PowerShell.

mshta.exe is *still* being abused in recent campaigns

Source: Microsoft Security Blog, ACR Stealer: Two observed intrusion chains amid increased threat activity [Jul 2026]

Bring Your Own Vulnerable Driver (BYOVD)

How BYOVD Attacks Work



Source: Picus Security

By exploiting a vulnerable driver's privileges, attackers can disable EDR components **to disrupt** telemetry collection, detection, or response

BYOVD in Genshin Impact's AC: mhyprot2.sys

CVE-2020-36603: mhyprot2.sys 1.0.0.0 AC kernel driver does not adequately restrict unprivileged function calls, allowing local, unprivileged users to execute arbitrary code with SYSTEM privileges on Microsoft Windows…

How the abuse works

User-mode app	Kernel-mode driver
Sends device control request (IOCTL)	Performs requested op with kernel privileges
Request termination of target process	Calls ZwTerminateProcess inside driver

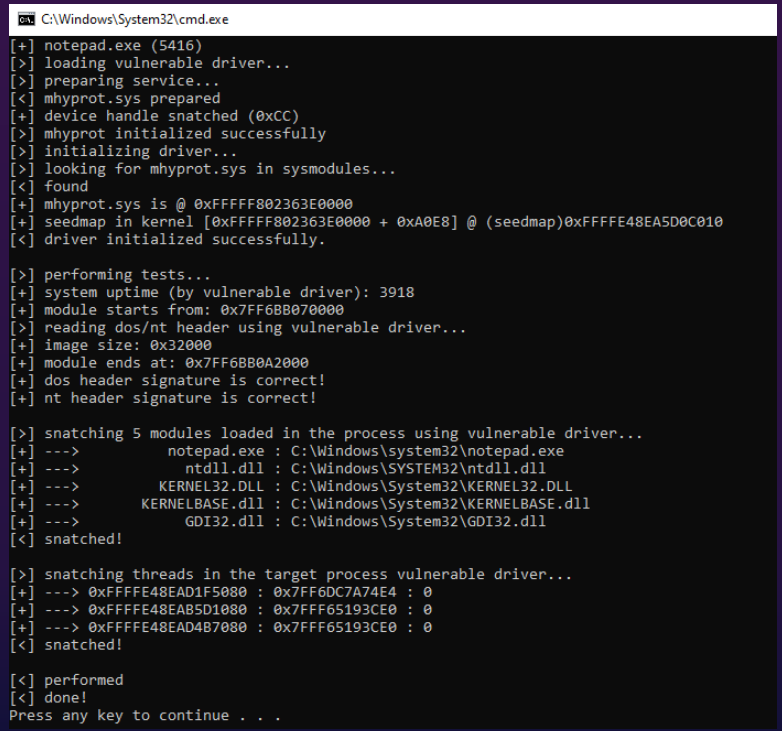
Public PoCs

evil-mhyprot-cli

A PoC for Mhyprot2.sys vulnerable driver that allowing read/write memory in kernel/user via unprivileged user process.

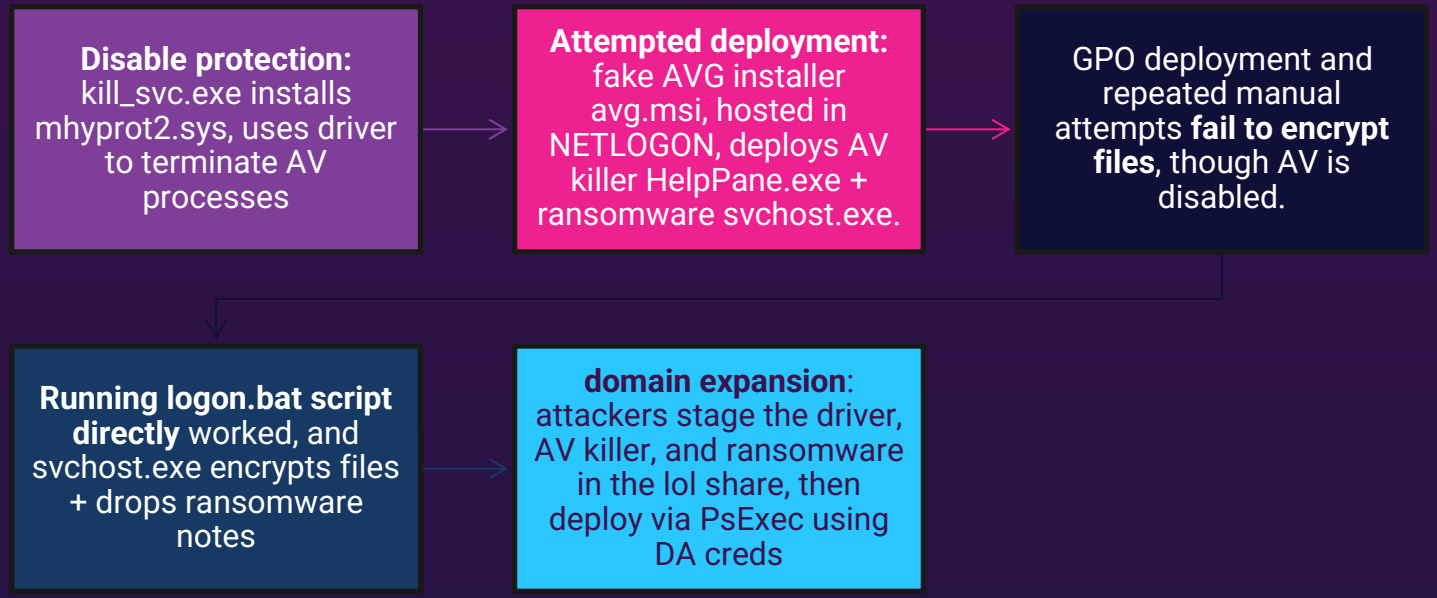
Mhyprot2DrvControl

A lib that allows using mhyprot2 driver for enum process modules, r/w process memory and kill process.



Source: Kento Oki (kkent030315), evil-mhyprot-cli [GitHub]
Source: kagurazakasanae, Mhyprot2DrvControl [GitHub]

In the wild: mhyprot2.sys used to disable AVs + deploy ransomware



I wanted to tweak evil-mhyprot-cli to test whether it could impair EDR agents on a Win11, but I kinda ran out of time :C future side project?

Source: Trend Micro, Ransomware Actor Abuses Genshin Impact Anti-Cheat Driver to Kill Antivirus [Aug 2022]

04 RESPONDING WHEN VISIBILITY IS IMPAIRED

What does “The EDR Was Bypassed” Mean?

- No relevant telemetry collected?
- Event collected, no detection?
- Alert generated but the activity was misclassified?
- Correct detection, but the response was too late?

[Extra] Johnathan Johnson’s Evadere Classifications that discusses categorizing evasion by where it affects the detection & response pipeline (eg. Collection, detection logic, triage)

IR Walkthrough

Qilin Ransomware using BYOVD

Who Is Qilin?

- RaaS group first identified in July 2022. Known for using **double extortion** (encryption + threats to publish stolen data
- **Most active ransomware operation** globally as of Aug 2026, accounting for 15% of recorded ransomware attacks and >160 attributed incidents

Incident Background [Dec 2024, Blackpoint Security]

- Qilin affiliates used compromised VPN access + MSP credentials, established a SSH reverse tunnel, and moved laterally via RDP and remote mgmt tools, DLL sideloading, and abused a signed Toshiba driver, TPwSav.sys to impair EDR telemetry

What we'll be covering



Source: Industrial Cyber, Ransomware activity hits 2026 high as industrial sector bears 31% of attacks and Qilin dominates [Sep 2026]
Source: Blackpoint Cyber, Qilin Ransomware and the Hidden Dangers of BYOVD [Jan 2025]

Qilin Ransomware:
Sequence of Events

1. VPN Access
On 12 December 2024, 31.192.107[.]144 established sessions lasting >six hours, then another 1.5 hours.

2. Additional Access
main.exe established SSH reverse tunnel to 216.120.203[.]26; attackers used RDP and remote mgmt.tools

3. Execution
Legitimate, signed upd.exe sideloaded malicious avupdate.dll

4 Payload Loading
DLL decoded web.dat, a customised EDRSandblast payload.

5 Kernel Tampering
TPwSav.sys supplied memory access used to modify Beep.sys, then interfere with kernel callbacks and event tracing.

6 Containment

Identification & Analysis

Establish compromise + actionables

Technical Context

TPwSav.sys provided kernel memory access → Beep.sys modified to interfere with callbacks + kernel ETW tracing → Impaired detections due to missing endpoint observations

Initial Assessment	Areas of Investigation
Establish affected hosts + identities	Identify hosts involved in suspicious VPN access, main.exe tunneling, bypass execution. Determine MSP account privileges + reach
Assess immediate damage	Check if encryption is occurring → File servers, backups/mgmt systems access
Evaluate remaining attacker access	Any suspicious active VPN/RDP/remote mgmt. sessions? Is SSH reverse tunnel still connected?
Check visibility + response capability	Which endpoint events are still arriving? What independent logs remain available? Can host isolation be enforced and verified?

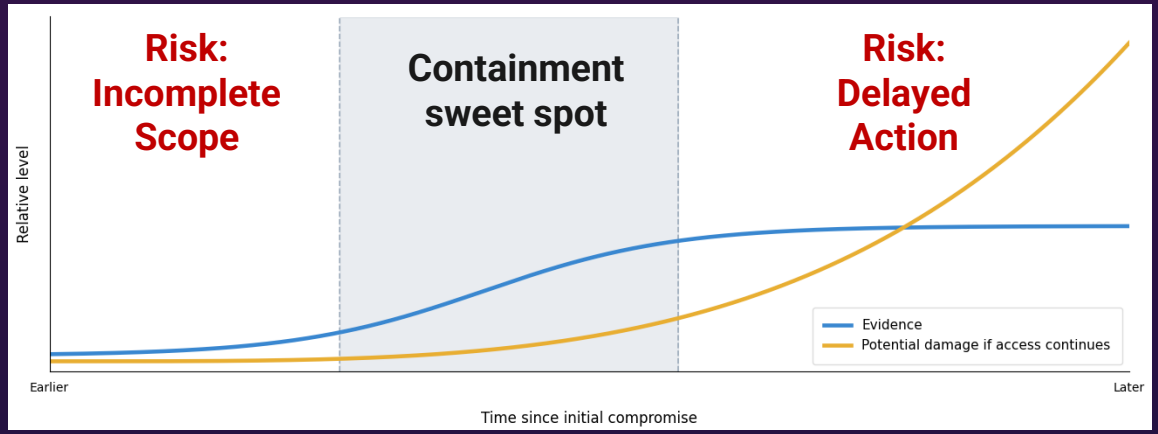
Reconstructing activity w. surviving evidence

Investigative Questions	Evidence to Examine	Limitations
How did access start?	SSL VPN sessions Account/MFA records Assigned VPN IPs	Shows account use, not how credentials were obtained or whether earlier access occurred.
Where did the MSP account go?	Dest logons, RDP records, DC authentication, RMM jobs	Logons don’t show subsequent actions
Where did the tooling run?	Deployment records, retained process/DLL events, disk artefacts for upd.exe, avupdate.dll, web.dat	File presence ≠ execution, successful deployment job ≠ successful bypass
When was telemetry impaired?	TPwSav.sys load records, event gaps, memory evidence of Beep.sys patches and callback changes	Driver load ≠ successful tampering
What access remained?	Active VPN/RMM sessions, tunnel connections, new accounts/services/tasks	Closing one route doesn’t remove others

Containment

Successful containment cuts off attacker access in one targeted sweep, and limits further harm while investigation continues.

Balancing Evidence vs Potential Damage



Eradication + Recovery

Aim: Remove every trace of attacker/ransomware from environment + safely restore bizops to a trusted state w/o risking reinfection

One possible approach

Remove persistence + alternate access	Rotate exposed credentials	Rebuild hosts with confirmed tampering after preserving required evidence	Validate telemetry, response functions, biz. services before reconnecting

Tradeoffs/Decisions To Consider

- Cleanup vs Rebuild
- Evidence vs Uptime
- Backup Recency vs Trust
- Speed vs Validation

05 CLOSING THOUGHTS

Takeaways

Understand how your EDR collects and detects activity: knowing its sensors and components helps you trace why an alert fired and troubleshoot gaps in coverage.

Scope what a bypass affects: identifying which observations it avoids/disables helps you assess attacker capabilities and remaining evidence

Balance the need for answers against the harm of waiting: ongoing attacker activity may require containment before the investigation is complete, while recovery still requires addressing remaining access and validating restored systems.

THANKS!

Any Questions?



Linkedin



Discord